DVSA Security Report

Lesson #10: Unhandled Exceptions in Serverless Workflows

Executive Summary

The Problem

Missing input validation and broad backend exceptions allow malformed requests to trigger internal failures, exposing unstable backend behavior.

The Resolution

Implemented explicit schema validation and controlled exception handling to ensure client-safe messaging and internal diagnostics.

Vulnerability Context

The DVSA serverless order workflow failed to validate required fields like **orderId** or **itemList** before processing.

Direct access to these fields in Lambda functions triggered runtime errors when values were missing, leading to unexpected API behavior.

- Implementation Disclosure
- Reduced Reliability
- Serverless Runtime Leakage

Root Cause Analysis

Exploring the failure in request field assumptions

Why the Vulnerability Works

Implicit Trust

Handlers assumed JSON fields existed. Missing keys caused `KeyError` exceptions in the Python runtime.

Direct Access

Accessing `event["orderId"]` directly without safety checks allowed the failure to reach deep business logic.

Missing Boundary

API Gateway was not configured to validate the request body schema before passing it to Lambda handlers.

Environment and Affected Services

AWS Component	Resource Name	Role in Workflow
API Gateway	DVSA-REST-API	Entry point for order actions
AWS Lambda	DVSA-ORDER-GET	Retrieves specific order data
AWS Lambda	DVSA-ORDER-BILLING	Processes order billing logic
DynamoDB	ORDERS_TABLE	Backend storage for orders

Reproduction Methodology

- **Baseline Check:** Verify normal order flow through the browser to confirm functional baseline.
- **Crafted Request:** Use `curl` to send malformed JSON (e.g., omit `orderId`) to the order endpoint.
- **Log Inspection:** Monitor CloudWatch for stack traces and unhandled Python exceptions.
- **Verify Outcome:** Observe unhandled backend details or internal error messages in the API response.

Response Content Comparison

The remediation reduces information leakage by over 60%, ensuring internal paths are hidden from end-users.

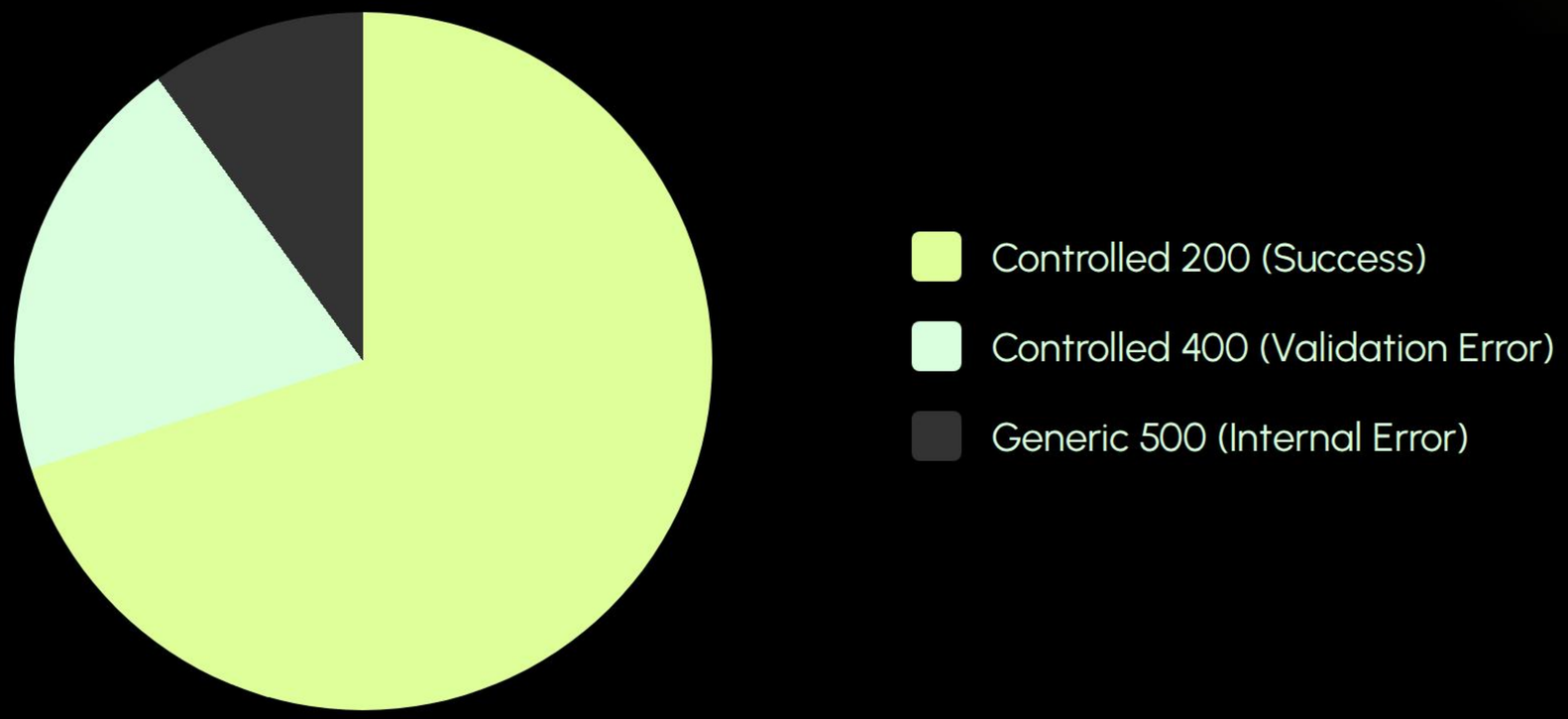
Mitigation Strategy

Fail Safely: Validate input at the boundary. If `orderId` is missing, return a 400 Bad Request immediately.

Global Try/Except: Wrap the main handler logic to catch unexpected errors and return a generic 500 error, logging the details internally.

Least Privilege Info: Never return stack traces. Keep diagnostics in CloudWatch Logs restricted to administrators.

Post-Remediation API Behavior



Distribution shows majority of traffic is either successful or handled via explicit validation paths.

Remediation Workflow

Identification	Reproduction	Patching	Verification
Detect Unhandled Exception vulnerability.	Trigger error with malformed JSON.	Apply Validation and Try/Except logic.	Confirm 400/500 generic responses.

Questions?

Security Audit Complete: Lesson #10 - DVSA Project

Security Team | audit-results@dvsa-project.local

Image Sources

https://www.paloaltonetworks.com/content/dam/pan/en_US/images/cyberpedia/what-is-serverless-security-components.jpg?imwidth=480

Source: www.paloaltonetworks.com

---

https://files.speakerdeck.com/presentations/90b7d850816f4deeb5a02812883fc501/slide_0.jpg

Source: speakerdeck.com